

Unseen Assessment

Unseen Assessment — DNP3 & MQTT (Analysis)

This is a **summative** assessment on captures you have **not** walked in the modules. Open the two files in Wireshark and answer from the evidence in the packets. Each attack uses a **different** technique than the teaching captures — reading the answer off a prior exercise will not work.

Captures: `pcaps/dnp3_assessment.pcap` and `pcaps/mqtt_assessment.pcap` **Student name / date:** _____

How you are graded: the analytic rubric at the end (four criteria × 0–3 = 12 points). **Mastery = ≥10/12, no criterion below 2, and you must correctly identify *which* frame is the attack in each capture.**

Part A — `dnp3_assessment.pcap`

Three IP addresses exchange DNP3 with one outstation; exactly one frame is malicious, and it is **not** a control command.

A1 (Identify). List each source IP, the DNP3 link address it uses, and classify it as *primary master*, *secondary read-only master*, or *neither* — citing the function codes each one sends as your evidence.

A2 (Identify + Justify). Give the frame number and packet type of the single malicious frame, and justify the call by naming **at least three** fields or facts that mark it as spoofed rather than a genuine outstation report.

A3 (Interpret). What false picture is that frame trying to paint for the operator? Using the legitimate poll data in the capture, state the **true** breaker position and system frequency at that moment.

A4 (Evaluate / Recommend-control). A colleague proposes: “Alert on any *SELECT*, *OPERATE*, *DIRECT OPERATE*, or *COLD RESTART* whose source IP is not 10.30.0.5.” Give **two independent** reasons this fails on this capture, then rewrite it so it catches the attack without alarming on the legitimate secondary master.

Part B — mqtt_assessment.pcap

Several legitimate clients use the broker; a rogue then connects and abuses a broker feature the teaching capture never used.

B1 (Identify + Interpret). Within milliseconds of its SUBACK the rogue receives PUBLISH packets it never asked a sensor for. Identify those frames and the **one field** proving they are stored **retained** messages rather than live telemetry. List each harvested topic and its most sensitive leaked value.

B2 (Analyze — authN vs. authZ + Interpret). Did the broker *authenticate* the rogue? Point to the two frames that answer this. Then classify the data harvest and the command publish as authentication or authorization failures, name the exact broker setting that permitted each, and — for the command publish — name the one flag that makes it persist and say what happens when the pump controller next reconnects.

B3 (Evaluate / Recommend-control). A vendor proposes to “fix” the broker by rejecting any subscription to `#`. Using this capture, explain why the attacker still succeeds at **both** the harvest and the injection, and name the two controls that actually close the gap.

Analytic rubric (0–3 each; 12 points total)

Criterion	0 — Not shown	1 — Emerging	2 — Proficient	3 — Mastery
Identify (locate the right frames/fields/actors)	Misidentifies a legitimate frame as the attack, or can't locate it	Vague/partial; wrong or incomplete frames	Finds the malicious frame and most actors; minor omission	Pinpoints the exact malicious frame(s) and every key actor by number, packet type, and address
Interpret (what the traffic means)	Misreads the protocol behavior	Surface reading; misreads a key field (RETAIN, link address, a value)	Mostly correct; one minor error	Correctly reads the fields and states real-vs-claimed state / retained-vs-live accurately
Justify (evidence tied to conclusion)	Assertion with no/wrong evidence	One field, or hand-wavy; conflates authN/authZ	Two correct fields; sound reasoning	≥3 independent correct fields; cleanly separates authentication from authorization
Recommend-control (fix / critique a detection)	No workable control, or one the capture shows would fail	Generic control, not tied to the evasion or false positives	Reasonable control, incomplete coverage	Control actually closes the gap and states what it does/doesn't cover; scoped to avoid false positives

Mastery threshold: ≥ 10 / 12, with **no criterion below 2**, and both attack-identification gates met — (A) name the DNP3 **spoofed UNSOLICITED RESPONSE** as the one malicious frame, and (B) identify the MQTT **retained command PUBLISH** as a persistent **write-authorization** abuse.

Missing either gate caps the result at *Approaching* regardless of point total. Bands: **Mastery 10–12** (+gates) · **Approaching 7–9** · **Not yet ≤ 6**. Re-attempts use a freshly generated capture (different addresses/values) to demonstrate transfer, not recall.